

CUMPLIMIENTO NORMATIVO

BY NOVA TECH SOLUTIONS

1. INTRODUCCION DEL CUMPLIMIENTO NORMATIVO

Con el fin de alinearnos con las disposiciones legales y regulatorias aplicables al negocio de NovaTech, en este apartado del Sistema de Gestión de Seguridad de la Información (SGSI) se tiene por objetivo identificar, documentar y consolidar el cumplimiento de las leyes y normativas vigentes que impactan las operaciones de la empresa.

Principalmente se describirán las obligaciones legales que la organización debe atender, así como los controles de seguridad implementados que permiten dar cumplimiento a dichas normativas. Estos controles son parte de la documentación del Sistema de Gestión de Seguridad de la Información (SGSI) orientadas a maximizar la confidencialidad, integridad y disponibilidad de la información, involucrando buenas prácticas y marcos de referencia estandarizados.

De esta manera, la empresa no solo busca evitar sanciones legales, sino también fortalecer la confianza de clientes, inversores y partes interesadas.

2. DATOS PERSONALES GESTIONADOS

El tratamiento de datos personales dentro de la organización es una actividad necesaria para el cumplimiento de sus objetivos operativos, administrativos y comerciales. En este sentido, la recopilación, almacenamiento y uso se realiza de manera legítima conforme a lo establecido en la Ley Federal de Protección de Datos Personales en Posesión de los Particulares, garantizando en todo momento el respeto a los derechos de los titulares.

En relación con la base de datos de clientes, los datos personales son utilizados con la finalidad de gestionar la relación comercial, proporcionar productos y servicios tecnológicos, realizar procesos de facturación, atención a clientes, soporte técnico y cumplimiento de obligaciones contractuales.

Por otro lado, los datos del personal son indispensables para la administración de recursos humanos, incluyendo procesos de reclutamiento, contratación, cumplimiento de obligaciones laborales, así como la evaluación del desempeño. En este caso, los datos pueden abarcar información de identificación, datos laborales, datos financieros y, cuando aplique, datos sensibles estrictamente necesarios.

Base de datos de clientes	Datos personales de empleados
- Nombre del cliente o empresa - CURP - Correo electrónico - Número telefónico - Domicilio comercial - Historial de compras o servicios contratados - Información de contratos - Información de facturación - Método de pago - Logs de acceso	- Nombre completo - RFC - CURP - Número de seguridad social - Domicilio - Teléfono personal - Correo electrónico - Puesto - Departamento de trabajo - Desempeño - Información contractual - Cuenta bancaria nominal - Estado de salud (En caso de ser necesario) - Datos biométricos (En caso de ser necesario)

3. OBLIGACIONES LEGALES

Para tener una mejor comprensión del alcance de este concepto, tenemos que bajo la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), el cumplimiento legal ante un incidente ya sea un ciberataque tradicional, extravío de documentos o un error humano, se centra en mitigar el daño al titular.

Ley Federal de Protección de Datos Personales en Posesión de Particulares (LFPDPPP)			
Artículo	Objetivo del artículo	Activos involucrados	Controles para el cumplimiento
Artículo 18	Asegurar la implementación de medidas de seguridad administrativas, técnicas y físicas para proteger los datos personales contra riesgos como acceso no autorizado, pérdida, alteración o destrucción.	- Base de datos de clientes - Datos personales de empleados	Para el cumplimiento de este artículo, contamos con controles que funcionan como servicio en caso de una brecha, así como tecnologías que nos apoyan para proteger la información y dar alertas en caso de anomalías. - Monitoreo de anomalías en el tráfico de datos - Evaluación de vulnerabilidad - Respaldos inmutables

Artículo 19	Establecer la obligación de informar oportunamente a los titulares sobre incidentes de seguridad que afecten significativamente sus derechos, permitiéndoles tomar acciones para su protección.	• Base de datos de clientes • Datos personales de empleados	Contamos con controles técnicos que se especializan solamente para dar alertas en casos de brechas de seguridad: • Reporte de anomalías • Análisis forense Post-Mortem obligatorio • Plan de comunicación de crisis pre-aprobado
Artículo 20	Garantizar que todas las personas involucradas en el tratamiento de datos personales mantengan la confidencialidad de la información, incluso después de finalizar su relación con la organización.	• Base de datos de clientes • Datos personales de empleados	Los datos, aunque ya no sean de utilidad para la empresa y el empleado, la organización los mantiene seguros hasta el momento en que cumpla su ciclo de vida. • Monitoreo de anomalías en el tráfico de datos • Respaldos inmutables
Artículo 37	Fomentar la adopción de esquemas de autorregulación que complementen la ley, mediante estándares, buenas prácticas y mecanismos que fortalezcan la protección de datos personales y faciliten el ejercicio de los derechos de los titulares.	• Base de datos de clientes • Datos personales de empleados	Básicamente el negocio se alinea a este artículo, ya que tiene documentado sus políticas y controles. • Capacitación y concientización • Gestión de identidades y accesos
Reglamento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares			
Artículo	Objetivo del artículo	Activos involucrados	Controles para el cumplimiento
Artículo 48	Implementar un sistema integral de gestión de privacidad que incluya políticas, capacitación, auditorías, gestión de	• Base de datos de clientes • Datos personales	Este artículo es en gran parte el sistema de gestión de seguridad de la información, pero sí queremos destacar alguno controles que este relacionados, tenemos:

	riesgos, atención a titulares, asignación de recursos y mecanismos de control para asegurar el cumplimiento de la normativa.	de empleados	• Capacitación y concientización • Evaluación de vulnerabilidad • Auditorías y métricas de desempeño
Artículo 61	Establecer un enfoque estructurado de seguridad de la información basado en inventarios, análisis de riesgos, análisis de brechas, implementación de controles, auditorías y capacitación continua.	• Base de datos de clientes • Datos personales de empleados	Los documentos de auditoría y métricas, controles de seguridad y capacitación y concientización son los que respaldan también la alineación con la ley. • Capacitación y concientización • Evaluación de vulnerabilidad • Auditorías y métricas de desempeño
Artículo 64	Garantizar la notificación oportuna a los titulares sobre vulneraciones de seguridad que afecten significativamente sus derechos, una vez confirmadas y evaluadas.	• Base de datos de clientes • Datos personales de empleados	• Reporte de anomalías • Análisis forense Post-Mortem obligatorio • Plan de comunicación de crisis pre-aprobado

Ley Federal del Derecho de Autor

Artículo	Objetivo del artículo	Activos involucrados	Controles para el cumplimiento
Artículo 102	Garantizar la protección legal de los programas de computación como obras intelectuales, abarcando tanto el código fuente como el código objeto, y excluyendo aquellos con fines maliciosos.	• Repositorios de código (Git) • Servidores de integración continua	El requerir de un sistema especializado para la organización, programarlo y documentarlo, hace propietario a la empresa del sistema. • Gestión e identidades y accesos • Desarrollo de software seguro • Gestión confidencial de credenciales
Artículo 103	Dictar los derechos patrimoniales de programas desarrollados por empleados en el ejercicio de sus	• Repositorios de código (Git) • Servidores de integración continua	Los empleados que escriben programas que ayudan a cumplir sus funciones para la organización hace que dicho código sea propio del negocio. Dicho código es gestionado

	funciones pertenecen al empleador, salvo acuerdo en contrario, asegurando la propiedad legal del software desarrollado dentro de la organización.		por: • Gestión e identidades y accesos • Desarrollo de software seguro
--	---	--	---

4. SANCIONES

En México, el régimen de sanciones varía dependiendo de si quien vulnera los datos es una **empresa/particular** o una **institución pública**. Con base en la ley vigente y el tipo de organización en la que NovaTech consiste, las faltas derivan en las siguientes sanciones:

Sector Privado (LFPDPPP - Empresas y Particulares)

Para empresas (bancos, apps, tiendas), las consecuencias suelen ser más severas y de carácter económico o penal:

- **Multas millonarias:** Dado el Artículo 59, las multas pueden ir desde los **100 hasta los 320,000 días de UMA**. Si la vulneración involucra **datos sensibles** (salud, biometría), la multa puede duplicarse.
- **Sanciones Penales (Cárcel):** A diferencia del sector público, aquí existen penas de prisión:
 - **3 meses a 3 años:** Por provocar una vulneración de seguridad en las bases de datos bajo custodia con fines de lucro.
 - **6 meses a 5 años:** Por tratar datos personales mediante engaño, aprovechándose del error del titular.
 - Las penas se duplican si se trata de datos sensibles.

2. Criterios para fijar la sanción

En ambos casos, la **Secretaría de Anticorrupción y Buen Gobierno** (antes el INAI) evalúa lo siguiente para decidir qué tan dura será la multa:

1. La **gravedad** del daño causado.
2. Si hubo **intencionalidad** (dolo) o fue un descuido.
3. La **capacidad económica** del infractor.
4. Si el suceso es **reincidente**.